

Narrativa Explicativa del Modelo de Encuesta SIEM

O cómo convertir logs, KPIs y siglas en una conversación razonable sobre riesgo, resiliencia y sentido común digital.

1. Por qué otra encuesta (y por qué esta)

En el universo observable, hay dos tipos de encuestas: las que se rellenan por obligación y se olvidan nada más darle a “Enviar”, y las que dejan al encuestado con la incómoda sensación de que quizá, solo quizá, hay cosas que podría estar haciendo mejor. Esta aspira a pertenecer, sin falsa modestia, a la segunda categoría.

El objetivo de la encuesta no es demostrar que la organización es perfecta ni desvelar secretos inconfesables, sino entender algo mucho más prosaico: **qué hace realmente el SIEM por la ciberseguridad de la casa, más allá de devorar gigabytes de logs y presupuesto**. Y, de paso, poner en común patrones y carencias que permitan mejorar la resiliencia del ecosistema nacional en su conjunto.

2. De los logs al riesgo: el hilo conductor

Durante años, el SIEM ha soportado estoicamente el papel de “cubo de datos” al que todo el mundo envía cosas por si acaso. La encuesta parte de la premisa de que esa fase debería estar superada: para 2026, un SIEM que no ayuda a responder preguntas de riesgo, cumplimiento y resiliencia empieza a ser un lujo difícil de justificar.

Cada sección del cuestionario pretende seguir la cadena de valor:

1. ¿Qué vemos? (arquitectura y cobertura).
2. ¿Con qué rapidez y calidad reaccionamos? (MTTD, MTTR, falsos positivos).
3. ¿A quién debemos rendir cuentas y con qué evidencias? (NIS2, ENS, DORA).
4. ¿Qué aprovechamos de la automatización y la IA para no morir de éxito bajo avalanchas de alertas?
5. ¿Qué papel juega todo esto en los indicadores de negocio y riesgo país?

Si alguna sección incomoda, probablemente sea la señal de que allí hay trabajo interesante por hacer.

3. Sobre el tono, las escalas y otras manías

El cuestionario utiliza escalas de 0 a 5, rangos porcentuales y alguna que otra pregunta abierta. No es una cuestión estética: los números concretos tienden a dar una ilusión de precisión que rara vez se sostiene en este dominio. Aceptamos, pues, rangos razonables y auto-evaluaciones explícitas.

El tono intenta ser lo bastante serio como para que lo firme un CISO sin sonrojarse, y lo bastante irónico como para que no parezca que la ciberseguridad es solo un ejercicio de cumplimiento litúrgico ante el regulador. El humor, cuando asoma, es también una estrategia de resiliencia.

4. Lo que nos dice cada bloque de preguntas

4.1 Perfil y arquitectura SIEM

Las primeras secciones sirven para situar el contexto: tipo de organización, tamaño, modelo de SOC, ámbito geográfico. No es lo mismo hablar de MTTD en una pyme que en un operador esencial de energía, aunque ambos vean pasar paquetes TCP.

La parte de arquitectura se interesa por:

- Qué fuentes de datos alimentan al SIEM.
- Qué porcentaje de activos críticos está realmente bajo vigilancia.
- Cómo de digeribles son los datos (normalización, parsing, modelo de datos).

Si una organización descubre que no sabe cuántos activos críticos envían logs al SIEM, el cuestionario ya habrá cumplido un propósito saludable.

4.2 Indicadores operativos

Aquí entramos en el terreno clásico: MTTD, MTTR, falsos positivos, cobertura de casos de uso. Se buscan dos cosas:

- Separar organizaciones que miden de las que intuyen.
- Distinguir entre métricas de escaparate y métricas que se usan para tomar decisiones (dimensionar el SOC, afinar reglas, justificar automatización).

Las preguntas sobre conversión alerta-incidente y carga por analista apuntan a un problema bien conocido: el SOC como fábrica de fatiga. Si la mitad del equipo vive pendiente de borrar ruido, algo falla.

4.3 Cumplimiento y reporting

El bloque regulatorio pretende comprobar en qué medida el SIEM se ha convertido en aliado fiable para:

- Cumplir plazos de notificación (NIS2, ENS, reguladores sectoriales).
- Producir evidencias estructuradas (logs, timelines, IoC) sin artesanía heroica.
- Mantener mapeos claros entre casos de uso y controles normativos.

Cuando una organización no puede responder cuánto tarda, de media, en notificar un incidente grave ni qué porcentaje notifica dentro de plazo, la conversación con el regulador corre el riesgo de volverse creativa.

4.4 IA, automatización y SOC moderno

No se trata de fetichismo tecnológico. La encuesta interroga la IA y el SOAR con una pregunta simple: ¿están aportando valor medible?

- Porcentaje de detecciones impulsadas por modelos de IA.
- Reducción de falsos positivos.
- Incidentes resueltos con automatización.

Si los modelos avanzados están en producción pero nadie sabe si reducen alertas, la organización ha comprado fuegos artificiales, no capacidades.

4.5 OT, 5G y otros mundos paralelos

En entornos donde cortar un cable implica parar una fábrica o dejar sin luz a una ciudad, la monitorización de OT/ICS no es un lujo, sino una obligación. El cuestionario pregunta si el SIEM ve algo más que servidores y estaciones de trabajo, y si hay métricas específicas para estos dominios.

Lo mismo con 5G: si se despliegan redes avanzadas pero la telemetría se queda en la caja negra del proveedor, es difícil hablar de gestión de riesgo con cara seria.

4.6 Riesgo, ROI y ecosistema

Por último, la encuesta intenta detectar si el SIEM se utiliza para:

- Alimentar la gestión de riesgos de la organización.
- Justificar inversiones en términos de ROI (aunque sea aproximado).
- Contribuir a la imagen de riesgo país mediante intercambio de métricas agregadas.

Una organización que consiga relacionar, siquiera de manera grosera, ciertos incidentes evitados con ciertos euros no perdidos, empieza a hablar el idioma que entiende mejor cualquier comité de dirección.

5. Qué hacer con los resultados (además de archivarlos)

5.1 A nivel interno de cada organización

Idealmente, cada organización podrá:

- Identificar brechas entre “lo que creíamos tener” y “lo que realmente medimos”.
- Priorizar acciones: por ejemplo, mejorar calidad de datos antes de desplegar más casos de uso; o formalizar la medición de MTTD y MTTR antes de prometer maravillas al regulador.
- Construir o refinar su propio cuadro de mando SIEM, con KPIs conectados a las secciones de la encuesta.

Las preguntas abiertas están ahí para recoger matices que el cuestionario, por definición, no puede anticipar.

5.2 A nivel agregado (sector, país)

En manos de un analista con algo de paciencia, la masa de respuestas puede:

- Revelar patrones por sector: dónde están las fortalezas y debilidades más recurrentes.
- Ayudar a orientar políticas públicas, guías del regulador y prioridades de inversión nacional.
- Alimentar índices de capacidad nacional, informes de ENISA o ejercicios de benchmarking internacional.

La condición indispensable es la agregación cuidadosa y la anonimización responsable. El objetivo es mejorar el ecosistema, no repartir calificaciones públicas.

6. Sobre la esperanza (y alguna ironía)

Si algo nos enseñan años de incidentes, informes y comités es que la ciberseguridad es tanto una cuestión de métricas como de cultura. Un SIEM puede registrar cada suspiro de cada paquete, pero si nadie mide lo que importa, el sistema seguirá siendo un magnífico contenedor de datos sin relato.

Esta encuesta, con toda su ambición y sus limitaciones, intenta contribuir a ese relato: ayudar a que los responsables de seguridad se sienten con negocio, riesgo y regulador a hablar de números que signifiquen algo más que “hemos procesado tantos millones de eventos”. Y si, de paso, provoca alguna sana incomodidad y unas cuantas mejoras trazables, habrá merecido la pena.

Fin de la narrativa explicativa.